Network Security and VPN Standard

Document ID	SEC-009
Department	IT and Information Security
Document type	Standard
Owner	Head of IT Operations
Version	1.1
Status	APPROVED
Effective / last reviewed	2026-02-08
Audience	All employees and contractors
Related documents	SEC-003, HR-003, SEC-008

Summary. Standard for network security at Northstar Systems covering NorthTunnel VPN with MFA, segmentation, default-deny firewalls, NorthGate production bastion with session recording, guest Wi-Fi isolation, remote work rules and quarterly firewall reviews.

SYNTHETIC DOCUMENT - Northstar Systems is a fictional company. This document exists for development, testing and demonstration only and is not real legal, employment, security or compliance advice.

1. Purpose and Scope

This standard sets the minimum network security controls for Northstar Systems Private Limited. It explains how employees connect to internal applications, how production systems are administered, how networks are segmented and how firewall rules are requested, reviewed and removed. The goal is to make sure that only authorised people and systems reach company resources, that production is isolated from corporate and guest networks, and that every administrative action in production can be traced.

The standard applies to all employees and contractors, to the Bengaluru Whitefield HQ, the Mumbai Powai office, remote workers across India, and to the cloud environments in the primary region Mumbai and the secondary (DR) region Hyderabad. It covers the NorthTunnel employee VPN, the NorthGate production bastion, office networks, Wi-Fi, cloud network zones, load balancers and web application firewalls (WAF). Encryption requirements for traffic are in SEC-008. Remote working rules are in HR-003, and access approval rules are in SEC-003.

2. Definitions

- **NorthTunnel**: the employee VPN that gives access to internal applications after authentication with NorthID and MFA.
- **NorthGate**: the production bastion or jump host. All production administration passes through it, and every session is recorded.
- **Default-deny**: a firewall posture where all traffic is blocked unless a rule explicitly allows it.
- **Zone**: a network segment with its own trust level, such as Corporate, Production, Management, Guest and Development.
- **WAF**: web application firewall placed in front of public endpoints.
- **Split tunnelling**: sending only some traffic through the VPN while the rest goes directly to the internet.
- **Firewall rule owner**: the named person or team accountable for the business need of a rule.

3. Roles and Responsibilities

Role	Responsibility
Head of IT Operations	Owns this standard, office networks, VPN service and Wi-Fi
Network Engineering	Implements and reviews firewall rules, maintains zones
Security Operations	Monitors NorthWatch for network alerts and reviews bastion sessions
Platform Engineering	Manages cloud network policies, load balancers and WAF
Rule owner	Justifies a firewall rule and confirms it each quarter
Employees and contractors	Use NorthTunnel and approved networks, never bypass controls

4. Network Architecture and Segmentation

Northstar networks are divided into zones. Traffic between zones is controlled and logged.

Zone	Purpose	Key rule
Corporate	Office LAN and employee laptops	Access to internal apps via NorthTunnel with MFA
Production	Customer-facing Nexus Platform services and databases	No direct inbound internet access except via load balancer and WAF
Management	NorthGate, NorthWatch collectors, CI/CD runners	Reachable only from approved sources
Development and staging	Non-production Nexus environments	No production data; separate credentials and keys
Guest	Visitor Wi-Fi in both offices	Isolated from the corporate network and internet-only

The following design principles must be applied:

1 Default-deny: firewalls and cloud security groups must start with deny-all and allow only documented flows.
2 Least exposure: databases, queues and internal APIs must have no public IP addresses.
3 Separate environments: production, staging and development must not share networks, credentials or encryption keys.
4 Egress control: production workloads may reach the internet only through controlled egress with allow-listed destinations.
5 Defence in depth: use network controls together with identity, encryption and application-level authorisation.

5. Employee Remote Access with NorthTunnel

Employees and contractors reach internal applications through NorthTunnel VPN, from home, hotels, customer sites or the office. The VPN requires NorthID authentication with MFA. Hardware security keys are required for privileged accounts.

Rules for NorthTunnel:

- Only company laptops enrolled in NorthGuard may connect. Personal laptops must not connect to NorthTunnel. Phones enrolled through NorthGuard mobile enrolment may connect only for email and NorthID.

- A device must be encrypted, patched (OS patches within 14 days of release) and have an active endpoint agent. Non-compliant devices are denied at connection time.
- Full tunnelling is the default for corporate laptops. Split tunnelling is not permitted for production-related work and requires Network Engineering approval for other uses.
- VPN sessions end after 12 hours, and the user must re-authenticate with MFA. Idle sessions disconnect after 30 minutes.
- Five failed sign-in attempts lock the account for 15 minutes.
- Users must not share VPN profiles, run VPN software on non-approved devices or install alternative VPN clients.
- Working from outside India or from a location other than the registered city for more than 10 working days in a year needs HR and Security approval, as described in HR-003. Access from unexpected countries is blocked by default and raised as an alert.

Example: A Support Engineer travelling to a customer site in Pune connects over hotel Wi-Fi. She starts NorthTunnel before opening NorthAssist or any internal tool. The client confirms device compliance and prompts for MFA. If she tried to use a public computer in a business centre, the connection would be refused because only enrolled company laptops are permitted.

6. Production Administration Through NorthGate

Production administration must go only through the NorthGate bastion. Engineers must not connect directly to production hosts, databases or Kubernetes-style control planes from laptops.

Procedure to get production access:

1 The engineer raises an Access Request in NorthDesk with the system, reason and the related change or incident ticket.
2 The approvals required are the reporting manager and the system owner, plus Director approval and a CISO delegate for privileged or production access.
3 Access is granted just-in-time for a maximum of 8 hours and expires automatically.
4 The engineer connects through NorthTunnel to NorthGate using NorthID with MFA and a hardware security key.
5 Every session is recorded, including commands and screen activity, and stored with the security audit logs retained for 24 months.
6 Security Operations reviews a sample of bastion sessions weekly and every break-glass use within 1 business day.

Production admin consoles use a 1-hour session timeout. Shared accounts are prohibited, so each administrative action ties to a person. Copying production data to a laptop is prohibited; data fixes need two-person review as required by the engineering standards.

Example: During a SEV2 incident, an on-call engineer needs a shell on a Tier-1 database host. She requests emergency access through NorthDesk, gets approval from the engineering Director on call and the CISO delegate, and receives 8-hour access. After the incident, the session recording is checked and the access expires.

7. Firewalls and Cloud Network Controls

All firewalls, cloud security groups and network access control lists follow default-deny.

7.1 Requesting a rule

1 Raise a NorthDesk firewall change request that states source, destination, port, protocol, duration, business reason and the rule owner.
2 Network Engineering checks that the request follows least privilege. Rules that allow any-to-any, a whole subnet, or a wide port range are rejected unless justified.
3 Changes to Production zone rules are Normal changes and need CAB approval with a rollback plan; urgent fixes follow the Emergency change process.
4 The change is applied and logged in NorthWatch. The rule owner confirms it works.

7.2 Review and clean-up

Firewall rules are reviewed every quarter. The review removes expired, unused and duplicate rules and confirms that each rule still has an owner and a business need. Temporary rules must carry an expiry date and are removed automatically. Rules without an owner after two review cycles are disabled for 14 days and then deleted if nobody objects.

7.3 Public exposure

No direct inbound internet access to production is allowed except through the load balancer and WAF. The WAF must block common web attacks and is tuned by Security Operations. Administrative ports such as SSH, RDP and database ports must never be open to the internet. The weekly vulnerability scan checks externally visible addresses, and an unexpected open port is raised as a High finding.

8. Office Networks and Wi-Fi

Corporate Wi-Fi uses certificate-based or NorthID-backed authentication. Guest Wi-Fi is isolated from the corporate network and gives internet access only; visitors register at reception, and guest credentials expire after 24 hours. Employees must not connect personal laptops to corporate Wi-Fi, and must not set up personal routers, switches or hotspots that bridge into the office network. Network ports in meeting rooms are disabled unless a NorthDesk request is approved.

Guest devices must never be given access to the Corporate or Production zones. Contractors with company laptops use the corporate network; contractors with their own devices are not allowed to use company resources.

9. Remote and Public Networks

When working remotely, users should use a trusted home network protected by a strong Wi-Fi passphrase and a router with up-to-date firmware. Public Wi-Fi may be used only with NorthTunnel active. Users must not discuss or display Confidential data in public places and must lock their screens. Employees on the fully remote plan receive a work-from-home allowance of INR 1,500 per month that covers internet and utilities, which should be used to maintain a reliable and secure connection.

10. Monitoring and Logging

Network logs from firewalls, VPN, WAF, DNS and NorthGate are sent to NorthWatch. Alerts are configured for port scans, repeated authentication failures, access from unusual countries, large outbound data transfers, new firewall rules in the Production zone and bastion sessions outside business hours. Security audit logs are kept for 24 months in tamper-evident storage, and time is synchronised through NTP. Security Operations reviews logs weekly. Suspected network intrusion

is reported to the Security Desk (ext. 5555) and handled under SEC-010.

11. Third-Party and Customer Connectivity

Vendors that need network access must first be assessed under SEC-011 and must connect through NorthTunnel vendor profiles with limited access, not through the Corporate zone. Site-to-site links to customers or partners need Security Engineering approval, documented IP ranges, encryption in line with SEC-008 and a named business owner. Customer integrations through Nexus Connect use the API gateway and OAuth 2.0 client credentials and do not need any network-level exceptions.

12. Exceptions and Escalation

A request for an exception, such as a split-tunnel profile for a lab or a temporary open port, must be submitted in NorthDesk and approved by the Head of IT Operations and the CISO delegate. The exception must have compensating controls and an expiry of no more than 90 days. Exceptions are reviewed each quarter with the firewall review. Breaches of this standard are reported to the Security Desk and handled under SEC-006 and the HR disciplinary process.

13. Additional Controls

DNS, email gateway and DDoS protection

Corporate and production DNS resolvers use filtering to block known malicious domains. Outbound DNS from servers must go only to approved resolvers. Public endpoints for the Nexus Platform are protected by the cloud provider's distributed denial-of-service protection and by rate limiting at Nexus Connect, which applies a default of 1,000 requests per minute per tenant. When an attack degrades a customer-facing service, the incident is declared as SEV1 or SEV2 under the engineering incident process and handled together with SEC-010.

Network access control for devices

Devices that connect to the office LAN are checked for NorthGuard enrolment. Unknown devices are placed in a quarantine segment that reaches only the enrolment portal. Printers, badge readers, cameras and other IoT devices are placed in a separate segment with no route to Production or to employee laptops. Their default passwords must be changed before connection, and their firmware is patched on the same cycle as other systems.

Cloud networking rules

In the cloud, every workload runs inside a private network with subnets per tier. Security groups are defined as code in version control and applied through NorthShip; manual changes in the console are detected as drift and reverted. Peering between production networks in Mumbai and Hyderabad is private, encrypted and limited to replication and backup traffic. Public object storage buckets are prohibited unless Public data is intentionally hosted and approved by the CISO delegate.

Minimum standards by data class

Data class	Allowed networks	Remote access
Public	Any	Any
Internal	Corporate, NorthTunnel	NorthTunnel with MFA

Data class	Allowed networks	Remote access
Confidential	Corporate, NorthTunnel	NorthTunnel with MFA on enrolled laptop
Restricted	Production zone, NorthGate only	Just-in-time access, session recorded

14. Worked Scenarios

Scenario 1: A new integration needs an inbound port

A Customer Success Manager wants a customer's system to push files to a Northstar server. The proposed solution is an open SFTP port to the internet. Network Engineering rejects the request because direct inbound internet access to production is not allowed. The alternative is to use a Nexus Connect connector over HTTPS through the load balancer and WAF, authenticated with OAuth 2.0 client credentials. The customer is given the connector details and no firewall change is needed.

Scenario 2: Quarterly firewall review finds an unowned rule

During the quarterly review, Network Engineering finds a rule allowing a development subnet to reach a Tier-2 database. The owner left the company six months ago. The rule is disabled for 14 days. Nobody objects, so it is deleted. The Head of IT Operations records the clean-up and adds a check so that leaver processing in NorthPeople prompts for a transfer of firewall rule ownership.

Scenario 3: Bastion session outside business hours

NorthWatch alerts Security Operations to a NorthGate session at 02:10 IST by an engineer who had no change ticket. Security Operations contacts the on-call manager and finds a SEV3 follow-up from the previous day. The session recording confirms the engineer only read logs. The access request is documented retroactively and the engineer is reminded that all production access needs a linked ticket before the session starts. If the session had shown unexplained commands, the matter would have gone to the Security Desk as a suspected incident.

Scenario 4: Contractor with personal laptop

A contractor developer joining a three-month project says that his personal laptop is faster than the one offered. Personal laptops must not be used for company work and cannot connect to NorthTunnel, so IT Operations issues a company laptop through the NorthDesk onboarding request. The laptop is enrolled in NorthGuard before the first connection, and the contractor's access is tied to the contract end date.

15. Frequently Asked Questions

- **Can I use my personal laptop on NorthTunnel for one urgent task?** No. Personal laptops must not connect. Contact the IT Service Desk (ext. 4000) for a loaner.
- **How long does a NorthTunnel session last?** 12 hours before MFA re-authentication.
- **How long can I hold production access?** At most 8 hours, granted just-in-time.
- **How often are firewall rules reviewed?** Every quarter.

16. Related Documents

See SEC-003 for access management, HR-003 for remote working, SEC-008 for encryption in transit, SEC-010 for incident response and SEC-011 for vendor connectivity.

17. Revision History

Version	Date	Change
1.0	2025-05-20	Initial standard
1.1	2026-02-08	Added idle disconnect, temporary rule expiry and vendor connectivity section